

Security assessment – findings report

CLIENT

MID-MARKET SAAS
(ILLUSTRATIVE)

PREPARED BY

WAYPOINT

ENGAGEMENT

ASSESSMENT

FRAMEWORKS

NIST CSF · ISO
27001 · CIS

§ 01 – EXECUTIVE SUMMARY

This assessment reviewed identity, cloud, detection, data, and resilience against NIST CSF 2.0, ISO/IEC 27001:2022 and CIS Controls v8. Overall maturity is **developing**: governance is reasonable, but standing privileged access, an exposed storage account, and the absence of out-of-hours detection concentrate the real risk. The findings below are prioritised by exploitability, with a 90-day roadmap.

2

CRITICAL

5

HIGH

8

MEDIUM

4

LOW

§ 02 – MATURITY SNAPSHOT

DIMENSION

CURRENT → TARGET

Identity & access



Cloud posture



Detection & response



Data & AI



Governance & compliance



Resilience & recovery



§ 03 – FINDINGS REGISTER (EXTRACT)

ID	FINDING	SEVERITY	CONTROL	STATUS
WP-001	Standing global administrator accounts without PIM ENTRA ID TENANT	CRITICAL	NIST PR.AA-05	OPEN
WP-002	Storage account exposed to public network AZURE – PROD SUBSCRIPTION	CRITICAL	CIS 3.3	IN PROGRESS
WP-004	Legacy authentication not blocked ENTRA ID CONDITIONAL ACCESS	HIGH	ISO A.8.5	OPEN
WP-007	No 24/7 alerting on identity sign-in risk MICROSOFT SENTINEL	HIGH	NIST DE.CM-01	OPEN
WP-011	Backups not tested for restore in 12 months BACKUP PLATFORM	MEDIUM	CIS 11.5	OPEN
WP-015	Secrets committed to source control history REPOSITORY – INTERNAL	MEDIUM	ISO A.8.24	REMEDIATED

EXTRACT OF 19 FINDINGS · FULL REGISTER DELIVERED WITH EVIDENCE ATTACHMENTS

§ 04 – REMEDIATION ROADMAP

0-30 DAYS

- Enrol all admins in PIM; enforce phishing-resistant MFA
- Close public exposure on the storage account
- Block legacy authentication (report-only → enforce)

30-90 DAYS

- Stand up 24/7 sign-in risk alerting and triage
- Run a restore test and document recovery time
- Rotate and vault the exposed secrets; add pre-commit scanning

90+ DAYS

- Move to continuous posture management with SLAs
- Quarterly access reviews and tabletop exercises
- Re-test and close findings only on evidence

ILLUSTRATIVE SAMPLE. DATA IS FICTIONAL AND DOES NOT REPRESENT A REAL CLIENT. A REAL ENGAGEMENT DELIVERS THE FULL REGISTER, EVIDENCE, AND A RE-TEST THAT CLOSSES FINDINGS ONLY WHEN THE FIX HOLDS. © 2026 WAYPOINT.